

APPENDIX G

Defense Human Resources Activity (DHRA)

Cybersecurity Requirements:

1. The Contractor and all Contractor personnel with access to or responsibility for nonpublic Government data under this contract shall comply with DoD Instruction 8500.01 Cybersecurity, DoD Instruction 8510.01 Risk Management Framework, NIST SP 800-53 Cybersecurity Controls and Enhancements, DoD Directive 5400.11 DoD Privacy Program, DoD 6025.18-R DoD Health Information Privacy Regulation, DoD 5200.2-R Personnel Security Program, and Homeland Security Presidential Directive (HSPD) 12.
2. The Contractor shall establish appropriate administrative, technical, and physical safeguards to protect any and all nonpublic Government data to ensure the confidentiality, integrity, and availability of government data. At a minimum, this must include compliance with DoDI 8500.01, DoDI 8510.01 and NIST SP 800-53 and provisions for personnel security and the protection of sensitive information, including Personally Identifiable Information (PII).
3. Contractor systems and information networks that receive, transmit, store, or process nonpublic government data must be accredited according to DoD Instruction 8510.01 Risk Management Framework (RMF) and comply with NIST SP 800-53 and annual Federal Information Security Management Act (FISMA) security control testing. All systems subject to RMF must present evidence of Assessment and Accreditation (A&A) testing in the form of an Authorization to Operate (ATO) and Cybersecurity Risk Assessment. Evidence of FISMA compliance must be presented in the form of a POA&M. The Contractor will be responsible for the cost of Cybersecurity A&A and FISMA testing required for any Contractor owned and operated network, facility and/or application processing DoD information.
4. The Contractor shall ensure all media containing sensitive information (e.g., hard drives, removable disk drives, CDs, DVDs) considered for disposal will be destroyed. Prior to destruction, media will be sanitized, i.e., all prudent and necessary measures shall be taken to ensure data cannot be retrieved through known conventional or unconventional means. USB Flash drive use is prohibited by DoD.
5. To the extent that the work under this contract requires the Contractor to have access to DoD sensitive information the Contractor shall after receipt thereof, treat such information as confidential and safeguard such information from unauthorized use and disclosure. The Contractor agrees not to appropriate such information for its own use or to disclose such information to third parties unless specifically authorized by the Government in writing.
6. The Contractor shall allow access only to those employees who need the sensitive information to perform services under this contract and agrees that sensitive information shall be used solely for the purpose of performing services under this contract. The Contractor shall ensure that its employees will not discuss, divulge or disclose any such sensitive information to any person or entity except those persons within the Contractor's organization directly concerned with the performance of the contract.
7. The Contractor shall be responsible for safeguarding all government equipment, information and property provided for Contractor use. At the close of each work period, government facilities, equipment, and materials shall be secured.

8. Contracting work performed shall be done using government provided email and resources. Resources include government furnished equipment. The Contractors company (and personal) computer shall not be used to perform to include store or transmit government work.
9. Final approval for all Cybersecurity tasks under this contract belongs to the Enterprise Service Directorate, Cybersecurity Division. The contractor is expected to obtain this final approval from Cybersecurity. All cybersecurity-related design, decisions, including cryptography, authentication, access control, data transfer and storage, Need-to-Know (NTK), or other IA technologies, must be coordinated with and approved by the Cybersecurity Division.
10. Government may terminate this contract for default if Contractor or an employee of the Contractor fails to comply with the provisions of this clause. The Government may also exercise any other rights and remedies provided by law or this contract, including criminal and civil penalties.

RMF Language for DOD Controlled or External Commercial Systems:

1. All Information Systems (IS), Platform Information Technology (PIT) and Information Technology (IT) Services or Products under this requirement, that receive, transmit, store, or process nonpublic government data must be accredited in accordance with Department of Defense (DOD) Instruction (DoDI) 8510.01 "Risk Management Framework (RMF) for DoD Information Technology (DIT)" issued March 12, 2014 (formerly the DOD Information Assurance Certification and Accreditation Process (DIACAP)). IS and PIT systems must be categorized in accordance with Committee on National Security Systems Instruction (CNSSI) 1253, implement a corresponding set of security controls from the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, and use assessment procedures from NIST SP 800-53A with additional DoD-specific assignment values, overlays, implementation guidance, and assessment procedures as required.
2. DoD-Controlled Information Systems (IS) and Platform Information Technology (PIT) Systems operated by a Contractor or other entity on behalf of the DOD; to include externally owned IS and PIT systems that are dedicated to DoD processing and are effectively under DoD configuration control must be authorized as DoD IS or PIT systems. The DHRA Authorizing Official (AO) must render an authorization decision for this type of a DoD system prior to DoD use of the capability.
3. External IT services provided by a commercial or other non-federal government entity under this requirement must ensure the security protections of the IS delivering the service is appropriate to the confidentiality, integrity, and availability needs of DHRA information and mission in order to be approved for acceptable use. DHRA will assess the adequacy of security proposed by potential service providers, and accept the proposed approach, negotiate changes to the approach to meet DoD needs, or reject the offer. The accepted security approach will be documented and included as attachments to the resulting contract.
4. External IT services in the form of commercial cloud computing services must comply with DoD cloud computing policy and procedural guidance as published.
5. Information security continuous monitoring (ISCM) is defined as maintaining ongoing awareness of information security, vulnerabilities, and threats to support organizational risk management

decisions. All IS and PIT under this requirement must maintain ongoing monitoring, analysis and incident response procedures as defined and documented in NIST SP800-137 as a critical part of the risk management process to ensure that IS and PIT operations remain within an acceptable level of risk, despite any changes that occur. In addition, all systems under this requirement must comply with all annual Federal Information Security Management Act (FISMA) security control testing and reporting requirements. The contractor will provide evidence of these compliance activities upon request of the government.

6. Following the guidelines documented in NIST SP 800-35 to evaluate and select resources that can be entrusted to optimally meet the IT security program requirements; the contractor must demonstrate their understanding of applying RMF to DOD and federal information systems as described in NIST SP 800-37 as well as the proper Assessment and Accreditation (A&A) procedures defined in NIST SP 800-115. The six-step RMF process includes security categorization, security control selection, security control implementation, security control assessment, information system authorization, and security control monitoring. The contractor will satisfy this requirement by providing appropriate evidence of their experience with these processes by submitting a sample of one or all of the following:
 - a. Security Plan (An overview of security requirements, description of agreed-upon security controls, and other supporting security-related documents);
 - b. A&A Security Test and Evaluation Plan (planning phase used to gather information needed for assessment execution—such as the assets to be assessed, the threats of interest against the assets, and the security controls to be used to mitigate those threat and to develop the assessment approach and required toolsets);
 - c. Security Assessment Report (Shows the results and recommended corrective actions for control weaknesses or deficiencies);
 - d. Plan of Action and Milestones (PO&AM) (Shows measures that are planned to correct weaknesses or deficiencies and to reduce or eliminate known vulnerabilities)

For all DOD controlled IS and PIT systems or external IT services provided by a commercial or other non-federal government entity under this requirement, the following requirements apply:

1. The contractor will provide documentation and evidence of the categorization and control selection process described in a Security Plan for the IS and PIT.
2. The contractor will provide documentation that the system has successfully gone through the RMF or NIST SP 800-171 r2, in order to integrate information security and risk management activities into the system's life cycle.
3. The contractor will be responsible for the cost of RMF processes and FISMA testing required for any contractor owned and operated network, facility and/or application processing DoD information that is not within a DoD enclave.
4. Technical security of the outsourced environment will be the responsibility of the contractor.